



GDRock – GDPR Basics

Free Guide 2026 · A practical introduction for EU-facing businesses

MAX TIER-2 FINE	MAX TIER-1 FINE	FINES ISSUED SINCE 2018
€20,000,000	€10,000,000	€4.5B+
or 4% global turnover	or 2% global turnover	across all EU countries

What Is GDPR?

The **General Data Protection Regulation (GDPR)** is the EU's data-protection law, in force since 25 May 2018. Its goal is simple: give EU residents control over their personal data and hold every organisation that touches that data accountable. **Location does not matter** — if you collect or process data from EU residents, GDPR applies to you, whether your business is based in Tel Aviv, New York, or Sydney.

Personal data includes:

- Names, email addresses, phone numbers
- Shipping & billing addresses
- IP addresses, browser cookies & device identifiers
- Payment & order history
- Marketing preferences & consent records

Who Must Comply?

You MUST comply if you...	Examples
Sell products or services to EU customers	Shopify store, digital downloads, SaaS, courses
Collect email addresses for marketing	Newsletter sign-ups, lead magnets
Use analytics, tracking or advertising cookies	Google Analytics, Meta Pixel, Hotjar
Process payments from EU residents	Stripe, PayPal, Mollie
Use third-party tools that receive EU data	Mailchimp, Klaviyo, HubSpot

Fine Tiers Explained

Tier	Max Fine	Applies to violations of
Tier 1	€10M or 2% turnover	Record-keeping, DPA obligations, data breach notification, data protection by design
Tier 2	€20M or 4% turnover	Core principles, lawful basis, consent conditions, data subject rights, international transfers

Key insight: Most fines come from basic mistakes — missing cookie banners, no privacy policy, failing to respond to data subject requests. Not intentional abuse.

5-Minute Compliance Checklist

Use this to assess where you stand right now:

■ You have a GDPR-compliant privacy policy published on your website
■ You show a cookie banner with real Accept and Reject buttons
■ Non-essential cookies do NOT load before consent is given
■ You have a named contact person for data-privacy requests
■ You have signed Data Processing Agreements with Shopify, Stripe, Mailchimp etc.
■ You have a data retention schedule (e.g. 7 yrs invoices, 3 yrs accounts)
■ You know what to do if a data breach happens in the next 72 hours

Your next step

Most issues can be fixed in under 30 minutes with the right templates. GDRock Core Pack includes everything: white-label privacy policy, cookie banner script, data retention table and breach response pack. gdrock.com/core · Use code **NEW10** for 10% off